

Beyond OWASP Top Ten: 13 Resources to Boost Your Security

What is OWASP?

The Open Web Application Security Project (OWASP) strives to help organizations and experts improve software security. This non-profit organization achieves this objective by providing free educational resources on its website.

The OWASP website includes many resources, including community forums, videos, free security tools, documentation, and the OWASP top 10 vulnerabilities list. The list is a popular resource that has become an industry standard. It identifies the most critical vulnerabilities to help prioritize remediation. Initially published in 2004, the list was updated in 2017 and 2021.

This is part of an extensive series of guides about [application security](#).

Why Is OWASP So Important in Application Security?

OWASP provides educational content freely to help mitigate security vulnerabilities. Before OWASP offered these resources, not much was available online, limiting developers to their individual knowledge and expertise.

OWASP documents Internet security threats and attack techniques that enable bad actors to exploit common security problems, showing how developers can address these issues at the technical and code levels. The organization provides information and specific hacking tactics and offers ways to fight against them.

Over the years, OWASP has helped the community protect code against cybersecurity vulnerabilities, improve software encryption, and reduce the number of security bugs, errors, and defects in code.

OWASP Top 10 Lists

1. OWASP Top 10 Web Application Risks

A web application vulnerability is a security weakness in software running on web browsers. Web access makes applications highly accessible but also exposes them to many attacks. Web applications are plagued by numerous security vulnerabilities, typically deriving from flawed code and misconfigurations.

Even though a web application can include many vulnerabilities, that does not mean you need to immediately remediate all of them. You can prioritize them using the OWASP Top 10 list, which includes the most critical web application threats. Data analysts determine eight vulnerabilities, while an industry survey identifies two additional threats.

The top 10 web app vulnerabilities are:

1. Broken Access Control
2. Cryptographic Failures
3. Injection
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable and Outdated Components
7. Identification and Authentication Failures
8. Software and Data Integrity Failures
9. Security Logging and Monitoring Failures
10. Server-Side Request Forgery

Learn more in our detailed guide to OWASP Top 10 (coming soon)

2. OWASP API Top 10

In 2019, the OWASP released an API Top 10 list to raise awareness about common API security risks. The API security threats list focuses on strategies and solutions to help understand and mitigate the vulnerabilities and security risks unique to APIs.

Here are top 10 API vulnerabilities included in the list:

1. Broken Object Level Authorization
2. Broken User Authentication
3. Excessive Data Exposure
4. Lack of Resources & Rate Limiting
5. Broken Function Level Authorization

6. Mass Assignment
7. Security Misconfiguration
8. Injection
9. Improper Assets Management
10. Insufficient Logging & Monitoring

3. OWASP Mobile Top 10

The mobile security project can help build and maintain secure mobile applications and devices. OWASP frequently updates the project with the latest attack trends and vectors to offer a development control that can reduce the likelihood and attack of attacks. It offers the OWASP mobile top 10 list, a testing guide, cheat sheets, and other resources to support secure development.

Here are the top 10 mobile vulnerabilities mentioned in this list:

1. Improper Platform Usage
2. Insecure Data Storage
3. Insecure Communication
4. Insecure Authentication
5. Insufficient Cryptography
6. Insecure Authorization
7. Client Code Quality
8. Code Tampering
9. Reverse Engineering
10. Extraneous Functionality

Other OWASP Projects and Tools

4. OWASP Zed Attack Proxy (ZAP)

OWASP ZAP is a web security tool that helps new and experienced security experts test a product's resiliency against attacks. It serves as a Man-in-the-Middle (MitM) proxy that intercepts and inspects the messages sent between a client and a tested web application. It includes APIs and security automation that help simplify the software security testing process.

Learn more in our detailed guide to OWASP ZAP (coming soon)

5. OWASP Cheat Sheet Series

The OWASP Cheat Sheet Series provides a set of best practices for securing software applications. The cheat sheet is abbreviated, eliminating the need to go through highly detailed and impractical documents. The OWASP Cheat Sheet Series provides practitioners with practical steps they can actually implement.

6. OWASP Juice Shop

OWASP's Juice Shop helps pen testers, developers, and other stakeholders test and exploit vulnerabilities. The juice shop includes a modern and sophisticated web application intentionally riddled with an insecure design modeled according to the OWASP Top 10 list of vulnerabilities.

Practitioners can use the OWASP Juice Shop to view and handle insecure scenarios in practice. This platform supports many use cases, including awareness demonstrations, security training, and capture the flag (CTF) events.

7. OWASP Software Assurance Maturity Model (SAMM)

The Software Assurance Maturity Model (SAMM) aims to provide an effective and measurable model to enable all organization types to analyze and improve their software security posture. OWASP SAMM is process- and technology-agnostic and supports the entire software lifecycle. It was built to be risk-driven and evolutive.

8. OWASP Dependency-Check

Dependency-Check is OWASP's software composition analysis (SCA) tool. It scans code at rest to identify publicly-disclosed vulnerabilities in your project's dependencies. It automatically updates its data using the NIST's NVD Data Feeds. It uses the data to match each dependency with a known common platform enumeration (CPE) identifier. When it finds a CPE, it generates a report that links to the associated CVE entries.

10. OWASP Application Security Verification Standard (ASVS)

The OWASP Application Security Verification Standard (ASVS) Project offers a list of requirements for secure development and a baseline for testing web application technical security controls. It helps establish confidence in an application's security and protect against vulnerabilities like SQL injection and cross-site scripting (XSS).

11. OWASP Mobile Security Testing Guide (MSTG)

The MSTG is a manual for testing mobile app security based on reverse engineering and security testing for Android and iOS. The guide sets standards for operating system security testing, providing various features. It includes security requirements, basic static and dynamic testing, mobile application reverse engineering and tampering, and software protection assessments.

12. OWASP Threat Dragon

OWASP Threat Dragon is a modeling tool that follows the principles and values of the threat modeling manifesto. It supports STRIDE / LINDDUN / CIA, implements a rule engine to auto-generate threats and mitigations, and provides modeling diagrams. You can run it as a desktop or web application to create threat model diagrams for a secure development lifecycle.

13. OWASP Webgoat

WebGoat is an intentionally insecure application that lets you test vulnerabilities common in Java-based applications with common open source components. It offers an interactive teaching environment for web application security.

Application Security with HackerOne

HackerOne and the community of ethical hackers is at the forefront of using OWASP to strengthen application security and make the Internet safer, referencing the OWASP Top 10 to prioritize their actions. Taking this approach one step further, the HackerOne Global Top 10 can enable application security teams to increase their effectiveness with timely insights, segmented by industry and fueled by exploitable findings submitted by ethical hackers. These findings are often new or found by innovative techniques and are unlikely to show up in the OWASP database. Combined, OWASP and HackerOne exploit databases assure that high severity vulnerabilities are found and fixed before bad actors can do their work.

Learn more about the HackerOne approach to [Application Security](#).

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

